



Institut Sabadell

Actividad 1: Análisis de tráfico HTTP con BurpSuite

CFGS Administració de sistemes informàtics i xarxes

Mòdul 08: Serveis de xarxa

Curs: 2025-2026

Activitat 1

Actividad 1: Análisis de tráfico HTTP con BurpSuite.....	1
1. Introducción.....	3
2. Objetivos.....	3
3. Preguntas teóricas de HTTP.....	4
4. Preparación del entorno.....	5
Captura de tráfico.....	5
5. Análisis a entregar.....	6
5.1 Peticiones HTTP.....	6
5.2 Respuestas HTTP.....	6
5.3 Enumeración de URLs.....	7
5.4 Análisis de seguridad (básico).....	7

1. Introducción

HTTP es el protocolo que permite la comunicación entre un cliente (normalmente un navegador) y un servidor web.

En esta práctica analizaremos **cómo se envían y reciben los mensajes HTTP** utilizando **BurpSuite**, una herramienta muy utilizada en ciberseguridad para interceptar, estudiar y modificar tráfico web.

El objetivo es que el alumno comprenda **cómo funciona realmente la navegación web**, qué tipo de peticiones realiza el navegador, qué cabeceras intervienen, cómo son las respuestas del servidor y qué información se puede extraer de ellas.

2. Objetivos

Al finalizar la práctica el alumno será capaz de:

- Comprender la estructura de **peticiones y respuestas HTTP**.
- Identificar **métodos HTTP**, **códigos de estado**, **cabeceras** y **cuerpos** de mensaje.
- Usar BurpSuite como **proxy de captura** para analizar tráfico real.
- Reconocer cómo el navegador solicita automáticamente múltiples recursos.
- Evaluar posibles implicaciones de **seguridad** en las comunicaciones web.

3. Preguntas teóricas de HTTP

1. ¿Qué diferencia hay entre una petición HTTP (Request) y una respuesta HTTP (Response)?

Petición HTTP (Request): Es lo que el cliente (por ejemplo, un navegador) envía al servidor para pedir información o realizar una acción. Contiene la URL, el método, cabeceras y a veces, datos en el cuerpo.

Respuesta HTTP (Response): Es lo que envía el servidor al cliente después de recibir la petición. Contiene un código de estado, cabeceras y, normalmente, el contenido solicitado.

2. ¿Qué función cumplen las cabeceras HTTP? Nombra al menos tres cabeceras importantes.

Las cabeceras HTTP transportan información adicional sobre la petición o la respuesta. Sirven para controlar cómo se envían o interpretan los datos, indicar tipo de contenido, controlar caché, autenticación, etc.

Ejemplos:

Content-Type: Indica el tipo de contenido.

Authorization: Para enviar credenciales o tokens de acceso.

User-Agent: Indica qué navegador o cliente está haciendo la petición.

3. Explica brevemente para qué se usan los métodos GET, POST y PUT.

GET: Se utiliza cuando alguien quiere solicitar información al servidor sin modificar nada. Los datos que envía aparecen en la URL, y el servidor devuelve la información solicitada.

POST: Se utiliza para enviar datos al servidor con el objetivo de crear un recurso nuevo o ejecutar alguna acción. Los datos van en el cuerpo de la petición y no en la URL.

PUT: Se utiliza para actualizar un recurso que ya existe en el servidor, enviando los datos que reemplazarán o modificarán el recurso actual.

4. ¿Qué representa un código de estado 200, 404 y 500?

200 OK: Indica que la petición se ha procesado correctamente y que el servidor devuelve la información solicitada.

404 Not Found: Indica que el recurso solicitado no existe en el servidor.

500 Internal Server Error: Señala que se ha producido un error en el servidor al procesar la petición.

5. ¿Qué es el campo Content-Type y por qué es fundamental en HTTP?

Content-Type es una cabecera que indica el tipo de contenido que se envía o recibe, como text/html, application/json o image/png.

Permite que el cliente o el servidor interpreten correctamente los datos. Por ejemplo, un navegador sabe si debe mostrar HTML, procesar JSON o descargar un archivo según esta cabecera.

6. ¿Qué son las cookies HTTP? ¿Por qué son tan importantes?

Son pequeños archivos de información que el servidor envía al cliente para almacenar datos entre distintas peticiones.

Són importantes porque permiten mantener sesiones abiertas, recordar preferencias del usuario, realizar seguimiento de actividad o gestionar la autenticación. Sin cookies, muchas aplicaciones web no podrían “recordar” quién es el usuario entre distintas visitas.

4. Preparación del entorno

1. Abrir **BurpSuite**.
2. Ir a: **Proxy** → **Intercept** → **OFF**.
3. Configurar el navegador para usar el proxy:
 - **IP:** 127.0.0.1
 - **Puerto:** 8080
4. Asegurarse de que en BurpSuite, en **Proxy** → **Options**, el listener está activo en ese puerto.

Captura de tráfico

Elige una web cualquiera (preferiblemente alguna que sea antigua)

Navega varios minutos y observa el tráfico capturado en:

Proxy → **HTTP history**

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
35	https://escolaguixot.org	GET	/								
82	https://escolaguixot.org	GET	/								
1	https://www.google.com	GET	/search?client=firefox-b-e&chann...	✓		200	86001	HTML		Google Search	
2	https://www.google.com	GET	/search?client=firefox-b-e&chann...	✓		200	760099	HTML		escola guixot - Buscar ...	
4	https://www.google.com	GET	/gen_204?atyp=i&ct=bxjs&cad=&b...	✓		204	663	HTML			
6	https://www.google.com	POST	/gen_204?ei=JX8oacGIL-jm7_UP5...	✓		204	663	HTML			
9	https://www.google.com	GET	/gen_204?atyp=i&ct=&cad=&rrwt...	✓		204	663	HTML			
11	https://www.google.com	POST	/gen_204?s=web&t=aft&atyp=csi...	✓		204	663	HTML			
13	https://www.google.com	POST	/gen_204?ei=JX8oacGIL-jm7_UP5...	✓		204	663	HTML			
14	https://www.google.com	POST	/gen_204?ei=JX8oacGIL-jm7_UP5...	✓		204	1270	HTML			
15	https://www.google.com	GET	/gen_204?atyp=i&ct=bxjs&cad=&b...	✓		204	1270	HTML			
16	https://www.google.com	POST	/gen_204?atyp=csi&ei=JX8oacGIL...	✓		204	663	HTML			
17	https://www.google.com	POST	/gen_204?atyp=csi&ei=JX8oacGIL...	✓		204	663	HTML			
25	https://www.google.com	GET	/client_204?atyp=i&biw=958&bih...	✓		204	704	HTML			
29	https://www.google.com	POST	/url?sa=t&source=web&rct=j&opi=...	✓		200	1304	HTML			
30	https://www.google.com	POST	/gen_204?atyp=i&ei=JX8oacGIL-j...	✓		204	663	HTML			
31	https://www.google.com	POST	/gen_204?atyp=i&ei=JX8oacGIL-j...	✓		204	663	HTML			
33	https://www.google.com	POST	/gen_204?atyp=i&ei=JX8oacGIL-j...	✓		204	663	HTML			
34	https://www.google.com	POST	/gen_204?atyp=i&ei=JX8oacGIL-j...	✓		204	663	HTML			
38	https://www.google.com	GET	/gen_204?atyp=i&ct=&cad=&rrwt...	✓		204	663	HTML			
39	https://www.google.com	POST	/gen_204?s=web&t=aft&atyp=csi...	✓		204	663	HTML			
40	https://www.google.com	GET	/gen_204?atyp=i&ct=backbutton&...	✓		204	663	HTML			
41	https://www.google.com	POST	/gen_204?atyp=csi&bb=1&ei=JX8o...	✓		204	663	HTML			
45	https://www.google.com	GET	/client_204?atyp=i&biw=958&bih...	✓		204	704	HTML			

5. Análisis a entregar

5.1 Peticiones HTTP

El alumno debe seleccionar **tres peticiones** y, para cada una, detallar:

- URL completa solicitada
- Método HTTP
- Cabeceras enviadas (mínimo: Host, User-Agent, Accept, Cookie si existe)
- Si contiene cuerpo (body), explicar qué datos incluye
- Razón por la que el navegador hizo esa petición (imagen, script, login, navegación...)

Petición 1:

657	https://ramardos.com	GET	/es/bachillerato/	
659	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓
660	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓
661	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓
662	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓
663	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓
664	https://www.google.com	GET	/async/bgasy?ei=tYsoabCCPup9u8...	✓
666	https://www.google.com	POST	/gen_204?atyp=i&ei=tYsoabCCPfu...	✓
676	https://ramardos.com	GET	/wp-includes/js/underscore.min.js...	✓
677	https://ramardos.com	GET	/wp-includes/js/backbone.min.js?v...	✓

Request
Pretty Raw Hex
1 GET /es/bachillerato/ HTTP/2
2 Host: ramardos.com
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://www.google.com/
8 Upgrade-Insecure-Requests: 1
9 Sec-Fetch-Dest: document
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Site: cross-site
12 Sec-Fetch-User: ?1
13 Priority: u=0, i
14 Te: trailers

En este caso no tiene body

Petición 2:

1378	https://agora.xtec.cat	GET	/ieslaromanica/	200	172345	HTML	
1379	https://www.google.com	POST	/gen_204?atyp=i&ei=HZgoaejzPM...	✓	204	694	HTML
1381	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓	200	20595	script
1382	https://www.google.com	POST	/gen_204?atyp=i&ei=HZgoaejzPM...	✓	204	694	HTML
1384	https://www.google.com	POST	/gen_204?atyp=i&ei=HZgoaejzPM...	✓	204	694	HTML
1385	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓	200	1040	script
1386	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓	200	20572	script
1388	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓	200	33342	script
1389	https://www.google.com	GET	/xjs/_/js/k=xjs.s.es.Zm3oFzlgxl4.2...	✓	200	2203	script
1390	https://www.google.com	POST	/gen_204?atyp=i&ei=HZgoaejzPM...	✓	204	694	HTML

Request	Response	
Pretty	Raw	Hex
1	GET /ieslaromanica/ HTTP/2	
2	Host: agora.xtec.cat	
3	Sec-Ch-Ua: "Chromium";v="139", "Not;A=Brand";v="99"	
4	Sec-Ch-Ua-Mobile: ?0	
5	Sec-Ch-Ua-Platform: "Linux"	
6	Accept-Language: en-US,en;q=0.9	
7	Upgrade-Insecure-Requests: 1	
8	User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0	
9	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,=b3;q=0.7	
10	Sec-Fetch-Site: cross-site	
11	Sec-Fetch-Mode: navigate	
12	Sec-Fetch-User: ?1	
13	Sec-Fetch-Dest: document	
14	Referer: https://www.google.com/	
15	Accept-Encoding: gzip, deflate, br	
16	Priority: u=0, i	

Tampoco tiene body

Petición 3:

1884	https://bewoy1cf1-dsn.algo...	POST	/1/indexes/products_list%3Aes_qu...	✓	200	28165	JSON	
1885	https://cdn.pccomponentes....	GET	/front/prod/bundle-73da30c55aee...		200	961	script	js
1886	https://cdn.pccomponentes....	GET	/front/prod/bundle-73da30c55aee...		200	1241	script	js
1887	https://pcc-catalog-cfworke...	POST	/article-promo/	✓	200	647	JSON	
1888	https://cdn.pccomponentes....	GFT	/front/prod/bundle-73da30c55aee...		200	6532	script	is

Request	Response		
Pretty	Raw	Hex	GraphQL
3	Content-Length: 15		
4	Sec-Ch-Ua-Platform: "Linux"		
5	Accept-Language: en-US,en;q=0.9		
6	Sec-Ch-Ua: "Chromium";v="139", "Not;A=Brand";v="99"		
7	Content-Type: application/x-www-form-urlencoded		
8	Sec-Ch-Ua-Mobile: ?0		
9	User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36		
10	Accept: */*		
11	Origin: https://www.pccomponentes.com		
12	Sec-Fetch-Site: cross-site		
13	Sec-Fetch-Mode: cors		
14	Sec-Fetch-Dest: empty		
15	Referer: https://www.pccomponentes.com/		
16	Accept-Encoding: gzip, deflate, br		
17	Priority: u=1, i		
18	Connection: keep-alive		
19			
20	{		
	"query": "ram"		
	}		

En el caso de esta petición en la parte de abajo se puede ver el body, donde pone "query : ram"

5.2 Respuestas HTTP

Seleccionar **tres** respuestas y analizar:

- Código de estado
- Cabeceras devueltas por el servidor (mínimo: Content-Type, Server, Set-Cookie si existe)
- Tipo de contenido devuelto
- Tamaño aproximado (Content-Length si aparece)
- ¿Es una respuesta estática (HTML, imagen) o dinámica (JSON, PHP generado...)?

Respuesta 1 (HTML):

```
Request  Response
Pretty  Raw  Hex  Render
1 HTTP/2 200 OK
2 Date: Thu, 04 Dec 2025 16:46:26 GMT
3 Server: mw-web.eqiad.main-68fb48f4b9-9wbxx
4 X-Content-Type-Options: nosniff
5 Content-Language: es
6 Accept-CH:
7 Last-Modified: Thu, 20 Nov 2025 16:46:26 GMT
8 Content-Type: text/html; charset=UTF-8
9 Age: 219
10 Accept-Ranges: bytes
11 X-Cache: cp6009 miss, cp6011 hit/1
12 X-Cache-Status: hit-front
13 Server-Timing: cache;desc="hit-front", host;desc="cp6011"
14 Strict-Transport-Security: max-age=106384710; includeSubDomains; preload
15 Report-To: { "group": "wm_nel", "max_age": 604800, "endpoints": [{ "url":
"https://intake-logging.wikimedia.org/v1/events?stream=w3c.reportingapi.network_error&schema_uri=w3c/reportingapi/network_error/1.0.0" }] }
16 Nel: { "report-to": "wm_nel", "max_age": 604800, "failure_fraction": 0.05, "success_fraction": 0.0}
17 Set-Cookie: WMF-Last-Access=04-Dec-2025;Path=/;HttpOnly;secure;Expires=Mon, 05 Jan 2026 12:00:00 GMT
18 Set-Cookie: WMF-Last-Access-Global=04-Dec-2025;Path=/;Domain=.wikipedia.org;HttpOnly;secure;Expires=Mon, 05 Jan 2026 12:00:00 GMT
19 Set-Cookie: WMF-DP=bfd2;Path=/;HttpOnly;secure;Expires=Fri, 05 Dec 2025 00:00:00 GMT
20 X-Client-IP: 80.59.197.13
21 Cache-Control: private, s-maxage=0, max-age=0, must-revalidate, no-transform
22 Vary: Accept-Encoding,X-Subdomain, Cookie, Authorization, User-Agent
23 Set-Cookie: GeoIP=ES:CT:Barcelona:41.40:2.10:v4; Path=/; secure; Domain=.wikipedia.org
24 Set-Cookie: NetworkProbeLimit=0.001;Path=/;Secure;SameSite=None;Max-Age=3600
25 Set-Cookie: WMF-Uniq=VFJw2lZWuIdQXQhEEGgcUwK_AAAAAFvdjbsqRY8_SUX09syELqtF9LJst-QVCqal;
Domain=.wikipedia.org;Path=/;HttpOnly;secure;SameSite=None;Expires=Fri, 04 Dec 2026 00:00:00 GMT
26 Content-Length: 230415
27 X-Request-Id: 6730e6cc-e556-4cbd-bd33-1c38fd670216
```

Respuesta 2 (JSON):

```
HTTP/2 200 OK
X-Content-Type-Options: nosniff
Date: Thu, 04 Dec 2025 16:50:00 GMT
Expires: Thu, 04 Dec 2025 16:50:00 GMT
Cache-Control: private, max-age=3600
Content-Type: application/json; charset=UTF-8
Strict-Transport-Security: max-age=31536000
Content-Security-Policy: object-src 'none';base-uri 'self';script-src 'nonce-H-w-SkwLvpRCSVaArhIeTw' 'strict-dynamic'
'report-sample' 'unsafe-eval' 'unsafe-inline' https: http://report-uri https://csp.withgoogle.com/csp/gws/cdt1
Cross-Origin-Opener-Policy: same-origin-allow-popups; report-to="gws"
Report-To: {"group":"gws","max_age":2592000,"endpoints":[{"url":"https://csp.withgoogle.com/csp/report-to/gws/cdt1"}]}
Accept-CH: Sec-CH-Preferences-Color-Scheme
Accept-CH: Downlink
Accept-CH: RTT
Accept-CH: Sec-CH-UA-Form-Factors
Accept-CH: Sec-CH-UA-Platform
Accept-CH: Sec-CH-UA-Platform-Version
Accept-CH: Sec-CH-UA-Full-Version
Accept-CH: Sec-CH-UA-Arch
Accept-CH: Sec-CH-UA-Model
Accept-CH: Sec-CH-UA-Bitness
Accept-CH: Sec-CH-UA-Full-Version-List
Accept-CH: Sec-CH-UA-WoW64
Permissions-Policy: unload=()
Content-Disposition: attachment; filename="f.txt"
Server: gws
X-Xss-Protection: 0
X-Frame-Options: SAMEORIGIN
Alt-Svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
```

Respuesta 3 (PHP):

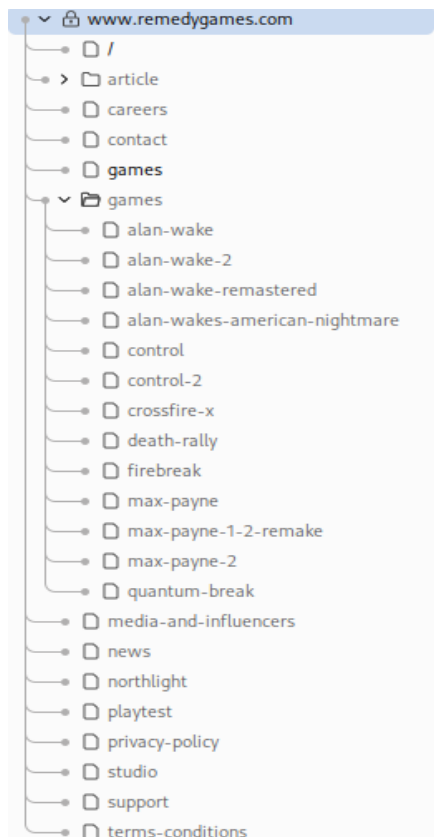
```
HTTP/2 200 OK
Date: Thu, 04 Dec 2025 17:40:06 GMT
Etag: W/"hre5g"
Expires: Thu, 04 Dec 2025 17:44:45 GMT
Cache-Control: public, max-age=300, s-maxage=300, stale-while-revalidate=60
Server: ATS/9.2.11
X-Content-Type-Options: nosniff
SourceMap: /w/load.php?lang=es&modules=startup&only=scripts&skin=vector-2022&sourceMap=1&version=hre5g
Content-Type: text/javascript; charset=utf-8
Accept-Ranges: bytes
X-Cache: cp6015 hit, cp6011 hit/340
X-Cache-Status: hit-front
Server-Timing: cache;desc="hit-front", host;desc="cp6011"
Strict-Transport-Security: max-age=106384710; includeSubDomains; preload
Report-To: { "group": "wm_nel", "max_age": 604800, "endpoints": [{ "url":
"https://intake-logging.wikimedia.org/v1/events?stream=w3c.reportingapi.network_error&schema_uri=w3c/reportingapi/network_err
or/1.0.0" }] }
Nel: { "report_to": "wm_nel", "max_age": 604800, "failure_fraction": 0.05, "success_fraction": 0.0}
X-Client-IP: 80.59.197.13
Vary: X-Subdomain,User-Agent
Age: 0
Content-Length: 62536
X-Request-Id: 9f6cb52d-9f66-4684-9f90-d2848c6f726e
```

5.3 Enumeración de URLs

El navegador solicita automáticamente múltiples recursos al cargar la web.

El alumno debe extraer:

- Lista de **las URLs detectadas por BurpSuite** (CSS, JS, imágenes, páginas internas, etc.)
- Clasificación entre recursos en una tabla:
 - HTML
 - Imágenes
 - Scripts
 - Peticiones AJAX
 - Formularios
 - Otros



5.4 Análisis de seguridad (básico)

Responder:

1. ¿Se utiliza HTTP o HTTPS?

Se utiliza principalmente HTTP.

2. ¿Las cookies incluyen atributos como **HttpOnly**, **Secure**, **SameSite**?

Revisando diferentes intercepciones no he encontrado ningún atributo de los que dice el título del ejercicio.

3. ¿Se observa información sensible transmitida en texto plano?

Al iniciar sesión en moodle puedo observar mi usuario y contraseña, es decir, mis credenciales de inicio de sesión.

4. ¿Alguna URL revela estructura interna del sitio?

Diversas URL revelan la estructura interna del sitio, de esta manera se puede ver el html

5. ¿Alguna respuesta indica errores del servidor (5xx)?

1	https://google.es	GET	/		301	1051	HTML	301 Moved
2	https://www.google.es	GET	/		301	1097	HTML	301 Moved
234	https://google.es	GET	/		301	1051	HTML	301 Moved
235	https://www.google.es	GET	/		301	1097	HTML	301 Moved
510	https://google.es	GET	/		301	1051	HTML	301 Moved
511	https://www.google.es	GET	/		301	1097	HTML	301 Moved
728	https://google.es	GET	/		301	1051	HTML	301 Moved
729	https://www.google.es	GET	/		301	1097	HTML	301 Moved
1024	https://frontaLies-sabadell...	GET	/eva		301	658	HTML	301 Moved Permanently
222	https://es.wikipedia.org	GET	/wiki/Special:CentralAutoLogin/st...	✓	302	1105	HTML	
1052	https://frontaLies-sabadell...	POST	/eva/login/index.php	✓	303	2416	HTML	php Redirigeix
1053	https://frontaLies-sabadell...	GET	/eva/login/index.php?testsession=...	✓	303	2013	HTML	php Redirigeix

Sí, diversas respuestas indican errores de servidor.